

Daily Vulnerability Report - 2026-09-16

Window (UTC): 2026-09-16T00:00 to 2026-09-17T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 10:06:40 UTC

Total	New	Updated	KEV	Critical	High	Medium	Unscored	Watchlist	Packages
1698	923	775	3	131	694	559	242	303	29

P1 - Act now (KEV / high EPSS)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76460 New	10.0	CRIT	Yes		cisco:identity services engine	A vulnerability in an API of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to bypass authentication. This vulnerability is due to insufficient authentication control on an API endpoint. An attacker could exploit this vulnerability by sending a crafted request to an affected API endpoint. A successful exploit could allow the attacker to gain unauthorized access to the affec...
CVE-2026-58704 Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-87886 Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20130 New	10.0	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20130 are...
CVE-2026-20192 New	10.0	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20192 are ...
CVE-2026-65381 Newly scored	10.0	CRIT		0.002	apple:macos	A validation issue existed in the entitlement verification. This issue was addressed with improved validation of the process entitlement. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious app may be able to break out of its sandbox.
CVE-2026-70416 New	10.0	CRIT				Dell ObjectScale, versions prior to 4.4.0.0, contains a Deserialization of Untrusted Data vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-76423 New	10.0	CRIT				A vulnerability in the REST API of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to gain administrative access to an affected device. This vulnerability is due to the REST API web service being exposed with insufficient authorization checks. An attacker could exploit this vulnerability by sending a crafted HTTP request to the exposed REST API port. A successful exploit could allow ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92808 New	10.0	CRIT				A server-side request forgery (SSRF) vulnerability exists in the UnifiedLogin service of Altium Enterprise Server. An unauthenticated network attacker can cause the server to issue outbound HTTP requests to a destination of the attacker's choosing, including internal services that are reachable only from the server itself. One such internal service exposes server configuration and credential material without a...
CVE-2026-16338 Newly scored	9.9	CRIT		0.006		IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to perform an arbitrary file write due to improper validation of file paths.
CVE-2026-20234 New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20234 are ...
CVE-2026-20307 New	9.9	CRIT				A vulnerability in the web-based management interface of Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have at least low-privileged administrative credentials. This vulnerability is due to insecure deserialization of a user-supplied Java byte stream. An attacker coul...
CVE-2026-20322 New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20322 are related to improper access control issues that are grouped unde...
CVE-2026-20324 New	9.9	CRIT				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure Firewall Management Center (FMC) Software could allow an authenticated, remote attacker to execute arbitrary commands as root. This vulnerability exists because a registered sftunnel peer has incorrect permissions to write an arbitrary file to any location on the device. An attacker could exploit this vulnerability by hijacking ...
CVE-2026-20325 New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20325 are related to improper neutralization of special elements used in ...
CVE-2026-20329 New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...
CVE-2026-20330 New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...
CVE-2026-20332 New	9.9	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...
CVE-2026-87719 Newly scored	9.9	CRIT		0.006		GitLab has remediated an issue in GitLab EE affecting all versions from 18.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could allow an authenticated user with Duo Chat access to obtain Advanced Search instance configurations and sensitive credentials using a specially crafted GraphQL subscription argument to bypass serialization and perform server object lookup.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-59953 New	9.8	CRIT			pip:lmdeploy fixed: 0.10.2	LMDeploy is a toolkit for compressing, deploying, and serving large language models. Starting in version 0.9.1 and prior to version 0.10.2, the LMdeploy implements an rpc server (AsyncRPCServer in zmq_rpc.py) for supporting the RPC communications. In its core functionality call_and_response(), I found it will directly use the pickles.loads() to deserialize the received messages without any sanitization, hence resu...
CVE-2026-12793 New	9.8	CRIT		0.004		The JetFormBuilder — Dynamic Blocks Form Builder plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 3.6.2. This is due to the plugin not validating that a submitted form ID belongs to a JetFormBuilder form before parsing the referenced post's content as form schema and executing an Advanced Validation server-side callback. This makes it possible for unauthenticated att...
CVE-2026-14349 New	9.8	CRIT		0.004		The TrueBooker – Appointment Booking and Scheduler System plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 1.2.3. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to modify the email address of arbitrary user accounts, including administrators, which can be leveraged ...
CVE-2026-20242 New	9.8	CRIT				A vulnerability in the External Database Access feature of Cisco Secure Firewall Management Center (FMC) Software could allow an unauthenticated, remote attacker to execute arbitrary commands as root on an affected device. This vulnerability is due to insecure deserialization of a user-supplied Java byte stream from a host that is configured in the external database access list. An attacker could exploit t...
CVE-2026-20326 New	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20326 are related to missing authentication for critical function issues that ...
CVE-2026-27546 New	9.8	CRIT		0.01		An unauthenticated remote attacker can exploit an authentication bypass in the _account_log function to log in as an admin, even when accounts are properly configured.
CVE-2026-27565 New	9.8	CRIT		0.009		An unauthenticated remote attacker can upload a malicious IODD file that places and executes a shell script with root privileges. The shell script remains active even after a reboot.
CVE-2026-54334 Newly scored	9.8	CRIT		0.004		UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, ReadCLen() in uefi_firmware/compression/Tiano/Decompress.c reads Number from GetBits(Sd, CBIT) with CBIT = 9 and can obtain 511 entries for the 510-element Sd->mCLen heap array because its loop does not enforce Index < NC. The CharC == 2 run-length path can additionally request up to ...
CVE-2026-57127 Newly scored	9.8	CRIT		0.009		PraisonAI is a multi-agent teams system. Prior to 4.6.58, recipe serve installs APIKeyAuthMiddleware or JWTAuthMiddleware when an operator selects api-key or JWT authentication, but each middleware forwards requests when PRAISONAI_API_KEY or PRAISONAI_JWT_SECRET and the corresponding recipe value are absent. Unauthenticated clients can then reach recipe execution, input, and output surfaces and may trigger connect...
CVE-2026-57131 Newly scored	9.8	CRIT		0.01		PraisonAI is a multi-agent teams system. Prior to 4.6.58, praisonai.jobs.server.create_app mounts praisonai.jobs.router.create_router under /api/v1/runs without authentication or per-job authorization. Network clients can submit attacker-controlled prompts and agent configuration, list and read jobs, stream results, and cancel or delete other jobs, exposing service credentials and connected tool capabilities to un...
CVE-2026-57967 Newly scored	9.8	CRIT		0.007	apache:artemis	An unauthenticated remote attacker can craft a CORE protocol SESSION_REATTACH packet to steal an existing session and assume ongoing execution of the previously authenticated session. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65414 Newly scored	9.8	CRIT		0.01	apple:ipados, apple:iphone_os, apple:macos, apple:visionos, apple:watchos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A remote attacker may be able to cause unexpected app termination or arbitrary code execution.
CVE-2026-66302 Newly scored	9.8	CRIT		0.005	microsoft:skype_for_business_server, microsoft:skype_for_business_server_subscription_edition	External control of file name or path in Skype for Business allows an unauthorized attacker to execute code over a network.
CVE-2026-68839 Newly scored	9.8	CRIT		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Mass Storage Class Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69829 Newly scored	9.8	CRIT		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Shell allows an unauthorized attacker to execute code over a network.
CVE-2026-69910 Newly scored	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows Hyper-V allows an unauthorized attacker to execute code over a network.
CVE-2026-70296 Newly scored	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds write in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-78573 Newly scored	9.8	CRIT		0.004	ibm:contextforge	IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.
CVE-2026-79724 Newly scored	9.8	CRIT		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-81204 Newly scored	9.8	CRIT		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.
CVE-2026-81467 Newly scored	9.8	CRIT		0.038	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82617 Newly scored	9.8	CRIT		0.003	apache:opennlp	The two built-in name-finder patterns exposed by <code>opennlp.tools.namefind.RegexNameFinderFactory - DEFAULT_REGEX_NAME_FINDER.EMAIL</code> and <code>DEFAULT_REGEX_NAME_FINDER.URL</code> - contain ambiguous nested quantifiers. An application that obtains these finders through <code>RegexNameFinderFactory.getDefaultRegexNameFinders(...)</code> and then applies them to untrusted text through <code>RegexNameFinder.find(String[])</code> or <code>RegexNameFinder.find(String...</code>
CVE-2026-84520 Newly scored	9.8	CRIT		0.001	apple:macos	A buffer overflow was addressed with improved size validation. This issue is fixed in macOS Golden Gate 27. A local attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84561 Newly scored	9.8	CRIT		0.002	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A double free issue was addressed with improved memory management. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-84609 Newly scored	9.8	CRIT		0.002		A permissions issue was addressed with improved path validation. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An app may be able to modify protected system files.
CVE-2026-85594 Newly scored	9.8	CRIT		0.002	traefik:traefik	Traefik versions from v3.7.1 fail to enforce <code>crossProviderNamespaces</code> restrictions on the <code>traefik.ingress.kubernetes.io/service.middlewares</code> Service annotation in the Kubernetes Ingress provider. A namespace-limited tenant excluded from the allowlist can attach an operator-owned middleware to its Service, and if that middleware injects backend credentials, recover them at a controlled backend.
CVE-2026-85595 Newly scored	9.8	CRIT		0.004	traefik:traefik	Traefik versions before v2.11.55 and versions v3.0.0 through v3.7.10 contain an authentication bypass vulnerability in the <code>digestAuth</code> middleware where unknown usernames receive an empty secret instead of rejection. Attackers can compute a valid digest response using the empty secret and arbitrary credentials to bypass authentication on any <code>digestAuth</code> -protected route without a valid username or password.
CVE-2026-85596 Newly scored	9.8	CRIT		0.002	traefik:traefik	Traefik versions <code>>= v3.7.0</code> and <code><= v3.7.10</code> contain an authentication bypass in the Kubernetes Ingress NGINX provider. The TLS option generated for an Ingress carrying the <code>nginx.ingress.kubernetes.io/auth-tls-secret</code> annotation was named after the Ingress namespace and name. As a result, two Ingress objects sharing the same host, the same client CA secret, and the same client-authentication mode produced two distinct...
CVE-2026-89778 New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: <code>isofs</code> : fix out-of-bounds page array access on empty <code>zisofs</code> block <code>zisofs_uncompress_block()</code> 's empty-block fast path returns <code>pcount << PAGE_SHIFT</code> , ignoring the incoming <code>poffset</code> , unlike the decompression path which returns bytes produced relative to <code>poffset</code> . <code>zisofs_fill_pages()</code> uses that return to advance its page cursor, so when the <code>zisofs</code> block s...
CVE-2026-89783 New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: <code>xfrm6</code> : fix out-of-bounds write in <code>xfrm6_input_addr()</code> when <code>secpath</code> is full The depth check in <code>xfrm6_input_addr()</code> is off by one: if <code>(1 + sp->len == XFRM_MAX_DEPTH)</code> goto <code>drop</code> ; ... <code>sp->xvec[sp->len++] = x</code> ; <code>xfrm_input()</code> can leave <code>sp->len == XFRM_MAX_DEPTH</code> , and the transport-mode receive path re-enters IPv6 input via <code>xfrm_trans_reinj...</code>
CVE-2026-89788 New	9.8	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: <code>ksmbd</code> : fix tree connection use-after-free in <code>smb2_tree_connect()</code> <code>ksmbd_tree_conn_connect()</code> publishes a new tree connection in <code>sess->tree_conns</code> with a single reference and returns its pointer to <code>smb2_tree_connect()</code> . The handler continues to initialize the object and build the response after publication. A concurrent session logoff can erase the c...
CVE-2026-89847 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: <code>scsi: qla2xxx</code> : Avoid double completion in <code>async IOCB</code> timeout <code>qla2x00_async_iocb_timeout()</code> tries to abort a timed-out <code>async IOCB</code> . When <code>qla24xx_async_abort_cmd()</code> fails, both the <code>SRB_LOGIN_CMD</code> path and the <code>SRB_CTRL_VP/default</code> path scan <code>outstanding_cmds[]</code> for the <code>SRB</code> and then call <code>sp->done(sp, QLA_FUNCTION_TIMEOUT)</code> unconditionally, without checking ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89857 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Hold qpair lock when sending NVMe LS reject qla_nvme_ls_reject_ioctx() allocates from and advances the request ring through __qla2x00_alloc_ioctxs() (which assumes the hardware_lock is held) and qla2x00_start_ioctxs() (which advances the ring and rings the request-in doorbell), but takes no lock itself. Two of its callers invoke it w...
CVE-2026-89969 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvmet-tcp: fix out-of-bounds write when receiving an over-long PDU nvmet_tcp_try_recv_pdu() reads a PDU header into the fixed 128-byte queue->pdu union, then computes the remaining payload length as queue->left = hdr->hlen - queue->offset + hdgsl; and reads that many more bytes into &queue->pdu + queue->offset, without ever bounding the resul...
CVE-2026-89970 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvmet-auth: Synchronize timeout work during SQ teardown nvmet_auth_sq_free() cancels auth_expired_work with cancel_delayed_work(). If the work has already started, cancellation does not wait for the callback. Transport teardown can consequently free or reuse the queue containing struct nvmet_sq while nvmet_auth_expired_work() still accesses that...
CVE-2026-89972 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: nvme: add missing SRCU grace period in error path nvme_alloc_ns() error path at out_unlink_ns removes ns from the namespace head siblings list with list_del_rcu(&ns->siblings) but does not wait for SRCU readers before freeing the namespace struct. Multipath code iterates the head->list under srcu_read_lock() in nvme_find_path() and nvme_mpath_re...
CVE-2026-89990 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: ceph: lock mutex in ceph_mds_check_access() MDS session OPEN handling replaces mdsc->s_cap_auths under mdsc->mutex, freeing the previous array and its strings. ceph_mds_check_access() traverses this array without holding the mutex. A concurrent session reopen can therefore free the array while it is being inspected, resulting in a use-after-fr...
CVE-2026-90012 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: spi: Fix DMA mapping ownership on partial map failure If RX mapping fails after TX mapping succeeds, __spi_map_msg() unmaps TX but leaves tx_sg_mapped set. If TX mapping fails on a later transfer, mappings created for earlier transfers remain active. In both cases, cur_{tx,rx}_dma_dev have not yet been updated because they are assigned only aft...
CVE-2026-90036 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during blocked-lock reaping A bare lock owner -- its only remaining reference a blocked lock on nn->blocked_locks_lru -- holds a raw pointer to its nfs4_client but no reference keeping the client alive. When the per-net laundromat reaps such a lock, freeing the nbl drops the owner reference held through flc_ow...
CVE-2026-90037 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during close_lru reaping An nfs4_openowner left on nn->close_lru after its final CLOSE keeps its last closed stateid in oo_last_closed_stid, holding only a raw pointer to its nfs4_client. The laundromat reaps timed-out entries, drops nn->client_lock, and calls nfs4_put_stid(), which dereferences the client thr...
CVE-2026-90038 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during export state revocation nfsd4_revoke_export_states() has the same use-after-free as nfsd4_revoke_states(): it drops nn->client_lock across revoke_one_stid() and the following read of clp->cl_minorversion, but the stateid reference it holds does not pin the client. A teardown racing the dropped lock can...
CVE-2026-90042 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: ceph: properly decrypt filenames in vmlloc() buffers The fsccrypt subsystem uses the scatterlist crypto API, inheriting its requirement that any buffers are in the linear mapping region. However, the messenger client uses kmmalloc() to create buffers for messages, which will occasionally place those buffers in the vmlloc() region when physical ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90048 New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix slab-out-of-bounds write in ni_create_attr_list() ni_create_attr_list() allocates a fixed buffer of al_aligned(record_size) (== record_size) bytes and then walks every attribute of the primary MFT record, writing one ATTR_LIST_ENTRY per attribute and advancing the cursor by le_size(name_len), with no check against the end of the bu...
CVE-2026-91843 New	9.8	CRIT				A stack overflow during the unauthenticated login process may allow an attacker to run arbitrary code remotely with root privileges.
CVE-2026-92787 New	9.8	CRIT				Feast through 0.66.0 fails to verify JWT token signatures before establishing user identity, allowing attackers to bypass all role-based access control by presenting an unverified token with a hardcoded claim value. Attackers can obtain trusted internal identity and gain unchecked read and write access to all entities, feature views, data sources, and permission policies on the server.
CVE-2026-92805 New	9.8	CRIT				UVdesk Community Skeleton through 1.1.8 fails to authenticate or validate installation state on wizard endpoints in ConfigureHelpdesk controller actions. Unauthenticated attackers can repoint the database and create super administrator accounts by submitting crafted requests to wizard endpoints, gaining full control of the instance.
CVE-2026-12944 Newly scored	9.6	CRIT		0.002		IBM Langflow OSS 1.0.0 through 1.10.0 can allow attackers to execute arbitrary Python code with root privileges (UID=0) on the Langflow server by submitting components containing socket or urllib imports. This enables: (1) AWS credential theft via IMDSv1 SSRF with full IAM role permissions, (2) arbitrary file exfiltration from the container filesystem, and (3) lateral movement to internal services (PostgreSQL, Red...
CVE-2026-20331 New	9.6	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...
CVE-2026-82107 Newly scored	9.6	CRIT		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-92716 New	9.6	CRIT				Shuffle through 2.2.1 contains a cross-tenant privilege escalation vulnerability in the HandleApiGeneration endpoint that allows administrators to reset and read API keys of non-administrator users in other organizations. Attackers with admin privileges in one organization can supply arbitrary user IDs to generate valid API keys for users in different organizations, enabling account takeover across tenant boundaries.
CVE-2026-15640 New	9.5	CRIT		0.003		Under certain conditions a valid SAML IdP response may be used to impersonate another Secret Server user.
CVE-2026-73453 New	9.5	CRIT		0.007		An unauthenticated P4Runtime (Programming Protocol-Independent Packet Processors Runtime) client can achieve arbitrary code execution under certain conditions on affected platforms running Arista EOS configured with P4Runtime. P4Runtime is disabled by default in Arista EOS. By crafting a malicious packet during the initiation of a P4Runtime session, an attacker can obtain complete administrative control over the c...
CVE-2026-77411 New	9.5	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, readLongstr in read.go returns an empty string and a nil error when a declared AMQP longstr length exceeds 0x7FFFFFFF instead of returning ErrSyntax. The function leaves the declared field bytes unread, while readTable treats the operation as successful and continues parsing from the wrong offset. A malicious or compromised broker can provide an overs...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58146 New	9.4	CRIT				WNC T-Mobile 5G Box IDU router is vulnerable to OS command injection vulnerability. The vulnerability exists within the /cgi-bin/portal.cgi endpoint, specifically through the cli_cookie POST parameter. The cli_cookie parameter value is directly concatenated into a find command string without proper sanitization. This allows a remote, unauthenticated attacker to inject and execute arbitrary shell commands as root o...
CVE-2026-73447 New	9.4	CRIT		0.008		A privileged attacker can exploit certain operation to execute arbitrary commands with root privileges, leading to full device compromise. An authenticated user can exploit gRPC Network Security Interface (gNSI) Certz service on Arista EOS-based products to escalate privileges and execute arbitrary OS commands via a crafted Certz Rotate request. The Bootz service is also affected.
CVE-2026-73461 New	9.4	CRIT		0.003		On affected EOS platforms with AAA-based gRPC authorization enabled for OpenConfig, gRPC requests of an authenticated user to OpenConfig may use the wrong privilege level, resulting in an authorization using the wrong AAA method list. This does not impact non-gRPC OpenConfig requests such as NETCONF.
CVE-2026-77405 New	9.4	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, tlsConfigFromURI in uri.go creates tls.Config values without setting MinVersion to tls.VersionTLS12. Builds using a Go runtime whose default permits TLS 1.0 or TLS 1.1 can therefore negotiate an obsolete protocol version when connecting through an amqps URI. A network attacker able to influence TLS negotiation with such a legacy build may weaken trans...
CVE-2026-81046 Newly scored	9.4	CRIT		0.004	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.
CVE-2026-85192 Newly scored	9.4	CRIT		0.005		Joomla Extension - regularlabs.com - Authenticated, privileged remote code execution in Conditional Content extension for Joomla < 8.0.0 - Conditional Content Pro accepts inline PHP Condition Rules in article syntax. In affected versions, the PHP is passed to the Conditions evaluator without checking who authored the article. Joomla's normal Author text filter preserves the syntax, so publishing the article causes...
CVE-2026-90680 Newly scored	9.4	CRIT		0.005		A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpy of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.
CVE-2026-90937 Newly scored	9.4	CRIT		0.003		froxl or versions before 2.2.5 fail to validate newline characters in subdomain redirect URLs, allowing authenticated customers to inject arbitrary nginx or Apache configuration directives. Attackers can supply URLs containing literal newlines that are written verbatim into vhost config files during cron rebuild, enabling web server configuration corruption, denial of service, or hijacking of HTTP responses across ...
CVE-2026-15639 New	9.3	CRIT		0.004		An attacker can craft a malicious link that, if used by a legitimate user, may cause the user's browser to run JavaScript supplied by the attacker.
CVE-2026-40855 New	9.3	CRIT				WNC T-Mobile 5G Box IDU router is vulnerable to a command injection. The vulnerability exists in the ping functionality within the /cgi-bin/portal.cgi endpoint, specifically affecting the ping_ip, ping_size, and ping_times POST parameters. The root cause is the failure to verify and sanitize user-supplied input before incorporating it into a system command. This allows an authenticated attacker to execute arbitrar...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58147 New	9.3	CRIT				WNC T-Mobile 5G Box IDU router contains an OS command injection vulnerability in the portal.cgi component's password change functionality. The application improperly neutralizes special elements in the http_passwd_hidden and http_passwdConfirm_hidden parameters, allowing an authenticated attacker to execute arbitrary commands on the underlying operating system with root privileges. This issue has been fixed in firm...
CVE-2026-73172 New	9.3	CRIT				Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the edgserver management service of Advantech EKI-1242EIMS in firmware version V1.06.01 that allows a remote unauthenticated attacker to execute arbitrary OS commands as root via crafted requests to TCP port 5058.
CVE-2026-89082 New	9.3	CRIT				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89083 New	9.3	CRIT				HP has identified potential security vulnerabilities in the HP Advance software that may enable elevation of privilege, remote code execution, or arbitrary file write under certain conditions, impacting the HP Advance server hosting the software.
CVE-2026-89775 New	9.3	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Handle negative S1 walk levels in VNCR TLB size evaluation Computing the effects of a TLB invalidation involves looking at the size of the mapping cached by the TLB. For S1 mappings such as VNCR, this is deducted from the combination of the base granule size and the mapping level. However, this implies that the S1 MMU is *on*. When ...
CVE-2026-89914 New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Sign-extend VA for range-based TLBI invalidation When the decode_range_tlbi() helper was moved to be used for S1 TLBIs, the required sign extension was omitted. Add it. As a result, special care must be taken to not overflow PA bits when this is used for S2 invalidation.
CVE-2026-89915 New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Remove VM-wide VNCR mapping counter The global VNCR mapping counter is used to decide whether an L1 provided VNCR page is mapped in L0 on any CPU at the point of dealing with a TLB invalidation. It is incremented when a mapping is made in the fixmap, and decremented when unmapped. As it turns out, this tracking has several flaws: -...
CVE-2026-89916 New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Make VNCR invalidation participate in MMU invalidation retry A VNCR TLB invalidation can occur on one vcpu while another vcpu is faulting in this same page. Without correctly handling this, we can end up with the following scenario: - vcpu A walks the PTs to translate VNCR - before vcpu A is able to grab the MMU lock to insert the T...
CVE-2026-89918 New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Correctly handle end of VA space TLBI invalidation Our TLB invalidation by VA code is based on comparing two ranges, one defined by the TLB, and one defined by the TLBI instruction. Each range is defined by a start and a size. However, the way the comparison is done doesn't account for address rollover, as it compares an address wit...
CVE-2026-89930 New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: KVM: nVMX: Service local TLB flushes on failed nested VM-Enter KVM services local TLB flushes on "full" nested VM-Exits (through __nested_vmx_vmexit()), but not if a nested VM-Enter fails (e.g. due to failed VMCS checks in nested_vmx_enter_non_root_mode()). However, it is possible that KVM had queued TLB flushes that need to be performed, even ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90049 New	9.3	CRIT				In the Linux kernel, the following vulnerability has been resolved: net: skbuff: don't skb_tx_error() the source skb in skb_zerocopy() skb_zerocopy() copies frags from @from into @to. On an skb_orphan_frags() failure it calls skb_tx_error(@from), a destructive operation on the source skb the copy helper does not own. That completes @from's zerocopy uarg and clears SKBFL_ALL_ZEROCOPY, including the SKBFL_SHARED_F...
CVE-2026-90945 Newly scored	9.3	CRIT		0.005		Crawlab through 0.6.3 uses a hard-coded HMAC-SHA256 secret for JWT token signing that cannot be overridden via configuration or environment variables. Unauthenticated attackers can forge valid administrator tokens to access administrative APIs and execute code on worker nodes.
CVE-2026-90961 Newly scored	9.3	CRIT		0.005		The LdapAuth and LinOTPAuth authentication plugins in MISP contain an authentication bypass vulnerability. Both LdapAuthenticate and LinOTPAAuthenticate replace CakePHP's FormAuthenticate class but fail to replicate its _checkFields() input validation guard. As a result, the email and password fields extracted from the login request are passed to downstream authentication logic without verifying that they are non-e...
CVE-2026-91104 New	9.3	CRIT				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-91106 New	9.3	CRIT				HP has identified and remediated multiple externally reported vulnerabilities within HPLIP. The findings affect several software components that could potentially enable remote code execution, privilege escalation, denial of service, information disclosure, or unauthorized file modification under certain conditions.
CVE-2026-73456 New	9.2	CRIT				Under certain circumstances on affected platforms running Arista EOS with gRPC Network Packet Sampling Interface (gNPSI) enabled, an unauthenticated gNPSI client can craft a malicious request to allow arbitrary code execution, granting an attacker full administrative control over the compromised switch.
CVE-2026-82067 Newly scored	9.2	CRIT		0.003	mongodb:mongodb	Improper handling of case sensitivity in the configuration validation component of MongoDB Server may cause the authorization subsystem to remain in a default disabled state during server startup. An unauthenticated user with network access to a deployment where this condition occurs can perform arbitrary administrative operations, resulting in full impact of data confidentiality, integrity, and availability.
CVE-2026-90562 Newly scored	9.2	CRIT		0.004		LangBot before 4.10.11 generates password recovery keys with only 24 bits of entropy and applies no rate limiting to the unauthenticated reset-password endpoint. Remote attackers knowing the administrator email can exhaust the keyspace through concurrent requests to reset the admin password and gain account access.
CVE-2026-15638 New	9.1	CRIT		0.002		An unauthenticated user with access to Secret Server could leverage a padding oracle to decrypt or encrypt data using one of the server's cryptographic keys. The key itself is not exposed.
CVE-2026-20176 New	9.1	CRIT				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid high-privileged administrative credentials. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafted HTTP...
CVE-2026-20194 New	9.1	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20194 are...
CVE-2026-20211 New	9.1	CRIT				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid high-privileged administrative credentials. This vulnerability is due to insecure deserialization of Java objects by the affected software. An attacker could exploit this vulnerability by sen...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20237 New	9.1	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC), engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20237 are...
CVE-2026-20284 New	9.1	CRIT				A vulnerability in the SXP REST API of Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks. This vulnerability is due to insufficient validation of user-supplied input in REST API calls. An attacker could exploit this vulnerability by sending crafted input to an affected device. A successful exploit could allow the attacker to view or modify data on the underlying database f...
CVE-2026-20305 New	9.1	CRIT				A vulnerability in the diagnostic tools of Cisco ISE and ISE-PIC could allow an authenticated, remote attacker to perform command injection attacks on the underlying operating system and elevate privileges to root. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of user-supplied input. An attacker could exploit this vu...
CVE-2026-20306 New	9.1	CRIT				A vulnerability in the REST API of Cisco ISE and ISE-PIC could allow an authenticated, remote attacker to perform command injection attacks on the underlying operating system and elevate privileges to root. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of user-supplied input. An attacker could exploit this vulnerability b...
CVE-2026-20341 New	9.1	CRIT				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software could allow an authenticated, remote attacker to obtain root privileges. This vulnerability is due to unsecured deserialization of untrusted data over the sftunnel management connection. An attacker could exploit this vulnerability by sending crafted sftunnel remote procedure calls (RPCs). A successful exploit ...
CVE-2026-43790 Newly scored	9.1	CRIT		0.003	apple:macos	The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause unexpected system termination or corrupt kernel memory.
CVE-2026-45764 Newly scored	9.1	CRIT		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workaround, disable HTTP/2 parsing if it is not ...
CVE-2026-49364 Newly scored	9.1	CRIT		0.004	apache:artemis	An unauthenticated network-adjacent attacker can leverage discovery to capture cluster administrative credentials during the initial cluster connection handshake. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-53713 Newly scored	9.1	CRIT		0.004		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, to_absolute_normalized_path in internal/gatewayapi/luavalidator/security.lua does not collapse redundant separators before is_critical_path evaluates Lua submitted through EnvoyExtensionPolicy during default Strict validation. Linux resolves a double-slash absolute pat...
CVE-2026-61594 New	9.1	CRIT			pip:djust fixed: 1.0.7	djust provides Phoenix LiveView-style reactive server-side rendering for Django with Rust-powered performance. Prior to version 1.0.7, the live (WebSocket) transport authorizes a mount via `check_view_auth`, not Django's `View.dispatch()` chain. As a result, standard Django authorization — `LoginRequiredMixin`, `PermissionRequiredMixin`, `UserPassesTestMixin`, `@method_decorator(login_required, name="dispatch")`, ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67593 Newly scored	9.1	CRIT		0.006	apache:artemis	A remote attacker can craft an Openwire RemoveSubscriptionInfo command to cause the deletion of a queue on the Artemis broker before the connection authentication and authorization stage or at any time thereafter. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-75156 Newly scored	9.1	CRIT		0.002		Apache Airflow FAB provider versions 3.7.3 through 3.8.0 do not validate the issuer or audience of Azure AD `id_token`s during OAuth login. Deployments are affected only when the FAB auth manager is configured with Azure AD as an OAuth provider. Because the signing keys are fetched from Microsoft's **multi-tenant** JWKS endpoint, an `id_token` minted in *any* Azure tenant — including one the attacker creates — pas...
CVE-2026-75513 New	9.1	CRIT				Marten is a .NET Transactional Document DB and Event Store on PostgreSQL. From version 7.0.0 until 9.13.0, several Marten LINQ and tenant-management paths interpolate runtime, potentially attacker-controlled strings into single-quoted SQL literals without escaping or parameterization. The primary confirmed vector is a dictionary indexer key used by Where filters in src/Marten/Linq/Members/Dictionaries/DictionaryIt...
CVE-2026-77408 New	9.1	CRIT				RabbitMQ amqp091-go is a Go AMQP 0.9.1 client. Prior to 1.13.0, the writeShortstr function in write.go casts the byte length of AMQP shortstr property values to uint8 without first rejecting values longer than 255 bytes. An application that accepts an oversized CorrelationId, ReplyTo, MessageId, Expiration, UserId, AppId, ContentType, ContentEncoding, or Type value can therefore serialize a wrapped length and only...
CVE-2026-78299 Newly scored	9.1	CRIT		0.003		In Eclipse Embedded CDT versions 6.0 to 6.7 if the CMSIS-Pack archive extracts a compromised CMSIS pack the archive extraction can extract files to locations outside of the pack, allowing writing of arbitrary files to other locations on disk.
CVE-2026-80424 Newly scored	9.1	CRIT		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-81642 New	9.1	CRIT		0.005		In NLnet Labs Unbound up to and including 1.26.0, a vulnerability was found in the DNSSEC validator that enables denial of service and possible remote code execution as a result of digesting DNSKEYs. A DNSKEY with an owner compression pointer to its own RDATA can overflow the digest buffer. Remote code execution is possible through attacker controlled data. An adversary can exploit the vulnerability by controlling...
CVE-2026-84625 Newly scored	9.1	CRIT		0.002		A permissions issue was addressed with additional sandbox restrictions. This issue is fixed in iOS 27 and iPadOS 27, macOS Golden Gate 27, visionOS 27, watchOS 27. An app may be able to fingerprint the user.
CVE-2026-85597 Newly scored	9.1	CRIT		0.002	traefik:traefik	Traefik before v2.11.55 and v3.0.0 through v3.7.10 contain a TLS option conflict resolution vulnerability that allows unauthenticated attackers to bypass client-certificate authentication by creating conflicting TLS options on multi-host routers. Attackers can reach protected backends by exploiting shared TLS resolution across multiple hostnames in a single router rule, causing the strict mTLS requirement to fail ...
CVE-2026-86881 Newly scored	9.1	CRIT		0.001	apple:ipados, apple:iphone_os, apple:macos, apple:tvos, apple:visionos, apple:watchos	A certificate validation issue was addressed with improved certificate validation. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. An attacker with a compromised intermediate certificate authority may be able to issue certificates with arbitrary extended key usages.
CVE-2026-89779 New	9.1	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: validate ef->size covers the record's name and value When an EA record has a non-zero ef->size, ntfs_read_ea() only checks that the record fits in the remaining buffer (ea_size > bytes), not that ef->size is large enough to hold the record's own name_len + 1 + elength. A crafted image can pass validation with, e.g., ef->size = 24 but ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89786 New	9.1	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: ext4: fix out-of-bounds read in ext4_read_inline_dir() ext4_read_inline_dir() can read a dirent header past the end of its inline buffer, triggering a slab-out-of-bounds read during getdents64(): BUG: KASAN: slab-out-of-bounds in __ext4_check_dir_entry Read of size 2 at addr ffff88800f3dd23c by task exploit/148 ... __ext4_check_dir_en...
CVE-2026-89846 New	9.1	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Bound rsp_info_len to avoid OOB sense-data read In qla2x00_status_entry(), the FWI2 status path advances sense_data and shrinks par_sense_len by rsp_info_len: if (IS_FWI2_CAPABLE(ha)) { sense_data += rsp_info_len; par_sense_len -= rsp_info_len; } rsp_info_len is a 32-bit value taken directly from the target's FCP response ...
CVE-2026-90011 New	9.1	CRIT				In the Linux kernel, the following vulnerability has been resolved: scsi: target: iscsi: Reserve a terminator byte for the login payload iscsi_target_check_login_request() rejects a login PDU whose DataSegmentLength exceeds MAX_KEY_VALUE_PAIRS, but the test is '>' and login->req_buf is allocated with exactly MAX_KEY_VALUE_PAIRS bytes. Since iscsit_get_login_rx() receives payload_length + padding bytes, where p...
CVE-2026-92395 New	9.1	CRIT				@fastify/proxy-addr is a Fastify plugin that determines a request's client address behind trusted reverse proxies, and it backs Fastify request.ip and request.ips. In versions 3.0.0 through 5.1.0, a trust subnet written in IPv4-mapped IPv6 notation with an IPv4-sized prefix, such as ::ffff:10.0.0.0/8 instead of the correct ::ffff:10.0.0.0/104, is accepted without error but trusts every IPv4 address on the internet...
CVE-2026-92717 New	9.1	CRIT				Covenant through 0.6 registers the CovenantHub SignalR hub without an Authorize attribute, allowing unauthenticated callers to invoke CreateHttpListener and receive a signed JWT token. Attackers can use the obtained token to authenticate against the entire operator API and access grunts, credentials, binaries, events, and the operator roster.
CVE-2026-92720 New	9.1	CRIT				Kubero through 3.1.1 fails to apply authentication guards to the notifications API endpoints, allowing unauthenticated attackers to read webhook secrets and service URLs. Attackers can retrieve stored credentials and register malicious webhooks to intercept pipeline events or suppress alerting by deleting existing configurations.
CVE-2026-76420 New	9.0	CRIT				A vulnerability in the internal configuration of the Apache JServ Protocol (AJP) connector for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to impersonate a peer device. This vulnerability is due to incorrect initialization of encryption parameters for the AJP connector at boot time. An attacker could exploit this vulnerability by sending crafted packets to the AJP connector. A...

Watchlist matches (other priorities)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20333 New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...
CVE-2026-20336 New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20340 New	8.8	HIGH				A vulnerability in Cisco Secure FMC Software could allow an authenticated, remote attacker to execute arbitrary commands at the root privilege level. This vulnerability is due to unsecured deserialization of web-management user-controlled data. An attacker could exploit this vulnerability by authenticating to the device and sending a crafted HTTP payload. A successful exploit could allow the attacker to sa...
CVE-2026-20344 New	8.8	HIGH				A vulnerability in the web-based management interface of Cisco Secure FMC Software could allow an authenticated, remote attacker to perform a SQL injection attack against an affected device. To exploit this vulnerability, the attacker must have a valid account on the device with the role of Security Approver, Access Admin, or Network Admin. This vulnerability is due to insufficient validation of user-supplied i...
CVE-2026-20360 New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20360 are related to information exposure and insecure handling issues that ar...
CVE-2026-20361 New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20361 are related to SQL injection issues that are grouped under the Common We...
CVE-2026-62706 Newly scored	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-66814 Newly scored	8.8	HIGH		0.004	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Insufficient granularity of access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-66818 Newly scored	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper privilege management in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-66819 Newly scored	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper neutralization of special elements used in an sql command ('sql injection') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-66820 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper neutralization of special elements used in an sql command ('sql injection') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67370 Newly scored	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper neutralization of special elements used in an sql command ('sql injection') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67373 Newly scored	8.8	HIGH		0.006	microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67380 Newly scored	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67381 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67384 Newly scored	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Integer overflow or wraparound in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67385 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use after free in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67388 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-69860 Newly scored	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-70203 Newly scored	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Media Player allows an unauthorized attacker to execute code over a network.
CVE-2026-71336 Newly scored	8.8	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Integer overflow or wraparound in Windows Work Folder Service allows an authorized attacker to execute code over a network.
CVE-2026-76409 New	8.8	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Nexus Dashboard engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76409 are related to improper limitation of a pathname issues that are grouped...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77495 Newly scored	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-84860 New	8.8	HIGH				ScadaLTS 2.8.1-release-candidate build 0 is affected by an Authorization Bypass Spring Security gates DWR endpoints by URL path pattern, but DWR itself dispatches method calls based on the POST body parameters c0-scriptName and c0-methodName. The crossDomainSessionSecurity setting in web.xml is set to false, which disables DWR's built-in origin validation. This means any authenticated user can invoke any DWR me...
CVE-2026-92122 New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not check the method called through the proxy created when a sandboxed script coerces a value to an interface, if the value inherits a method of the same name as an interface method, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and execute arbitrary code in the cont...
CVE-2026-92123 New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not intercept operations performed on a null receiver (method calls, property and attribute accesses, and array accesses), allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and execute arbitrary code in the context of the Jenkins controller JVM.
CVE-2026-92124 New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier checks the operations Groovy will perform with the elements it reads from a collection that a sandboxed script casts to another type but performs the cast on the collection itself, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and execute arbitrary code in the context of ...
CVE-2026-92125 New	8.8	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not reject the @GroovyASTTransformationClass annotation, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to run an arbitrary AST transformation at compile time, bypassing the sandbox protection and executing arbitrary code in the context of the Jenkins controller JVM.
CVE-2026-92137 New	8.8	HIGH				Jenkins Robot Framework Plugin 6.2.2 and earlier does not check that the archive directory configured for Robot Framework report files is contained within the build directory on the Jenkins controller, allowing attackers with Item/Configure permission to create or replace arbitrary files on the Jenkins controller file system with attacker-specified content, which can lead to remote code execution.
CVE-2026-92466 New	8.8	HIGH				zlt2000 microservices-platform through 6.0.0 contains a missing authorization vulnerability where the zlt.security.auth.urlPermission.enable flag defaults to false, disabling all permission checks after authentication. Authenticated users with no roles can access administrative APIs including user management, role assignment, and Elasticsearch index operations by bypassing the disabled authorization enforcement.
CVE-2026-92762 New	8.8	HIGH				Pelican Panel versions before 1.0.0-beta35 enforce startup write permissions only through disabled form controls rather than server-side authorization checks. Attackers with startup.read permission can craft Livewire state updates to invoke afterStateUpdated callbacks and modify startup commands, docker images, and variables to execute arbitrary commands in the container.
CVE-2026-82028 Newly scored	8.7	HIGH		0.004		Magistrala before 1.0.0 contains a SQL injection vulnerability in the timescale-reader and postgres-reader HTTP API services that allows authenticated attackers to inject arbitrary SQL by supplying a malicious format query parameter that is interpolated directly into the FROM clause without parameterization or identifier quoting. Attackers with a self-registered account can substitute arbitrary subqueries to achie...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82064 Newly scored	8.7	HIGH		0.003	mongodb:mongodb	A security issue in MongoDB Server allows an unauthenticated network user to cause a denial of service on a specific type of replica set member. The server contains an assertion in its read concern processing logic that can be reached without authentication, and the assertion's assumptions about internal state do not hold for all member configurations, causing the server process to terminate.
CVE-2026-82075 Newly scored	8.7	HIGH		0.003	mongodb:mongodb	An uncontrolled resource consumption weakness exists in the request-handling path of the MongoDB sharded-cluster router process. A client that has network access to a router port and has not authenticated can supply connection-monitoring parameters that cause the server to expend CPU resources without any rate limiting, degrading or denying service to legitimate clients. No authentication, elevated privileges, or ...
CVE-2026-20135 New	8.6	HIGH				A vulnerability in the TLS 1.3 implementation in Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause an affected device to reload unexpectedly, resulting in a denial of service (DoS) condition. This vulnerability is due to improper buffer management during the TLS 1.3 connection. An attacker could exploit this vulnerability by sending a crafted TLS 1.3 pa...
CVE-2026-20154 New	8.6	HIGH				A vulnerability in the system rate-limiting process for syslog message 419002 of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause high CPU utilization on an affected device, resulting in a denial of service (DoS) condition. This vulnerability is due to improper rate limiting for syslo...
CVE-2026-20249 New	8.6	HIGH				A vulnerability in the certification authentication feature of Internet Key Exchange version 2 (IKEv2) for Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause an affected device to reload unexpectedly. This vulnerability is due to a logic error during the certificate authentication ...
CVE-2026-20250 New	8.6	HIGH				A vulnerability in Datagram TLS (DTLS) message handling of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software for Cisco Secure Firewall 3100 Series and 4200 Series devices could allow an unauthenticated, remote attacker to cause a denial of service (DoS) condition on an affected device. This vulnerability is due to improper resource managemen...
CVE-2026-20295 New	8.6	HIGH				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software and Cisco Secure FTD Software could allow an unauthenticated, remote attacker to exhaust the available memory of an affected device. This vulnerability is due to improper management of memory resources during sftunnel TLS connection setup. An attacker could exploit this vulnerability by sending crafted sftunnel TLS ...
CVE-2026-20352 New	8.6	HIGH				A vulnerability in the RADIUS feature of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to cause a denial of service (DoS) condition on an affected device. This vulnerability is due to improper handling of certain RADIUS requests. An attacker could exploit this vulnerability by sending a crafted RADIUS request directly to an affected device. A successful exploit could allow...
CVE-2026-54628 Newly scored	8.6	HIGH		0.003		Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes URL-capable SQLite virtual table modules such as json_reader and log_reader through its unauthenticated MySQL-compatible server port without restricting outbound destinations. A remote attacker can provide a loopback, private-network, or link-local cloud metadata URL, causing go-getter in the Anyquery server process to ...
CVE-2026-56100 Newly scored	8.6	HIGH		0.003		SpringBlade versions from 2.7.3 up to but not including 5.0.0 contain a privilege escalation vulnerability that allows authenticated attackers to create system administrator accounts by sending crafted POST requests to an unprotected internal Feign user-creation endpoint exposed via @RestController without authorization checks. Attackers can exploit the gateway's authentication filter, which only validates JWT par...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67378 Newly scored	8.5	HIGH		0.005	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Untrusted pointer dereference in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67379 Newly scored	8.5	HIGH		0.006	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Stack-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-76412 New	8.5	HIGH				A vulnerability in the remote diagnostics debugger of Cisco Secure FMC Software could allow an authenticated, remote attacker to enable the remote diagnostics debugger service. This vulnerability is due to an error when checking the privilege level of a user who is invoking remote diagnostics. An attacker could exploit this vulnerability by authenticating to the device, either through the web-based management i...
CVE-2026-79708 New	8.5	HIGH		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 19.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions could have allowed an authenticated user with developer permissions to execute a policy test pipeline on projects within their group and access protected CI/CD variables restricted to higher-privileged roles, due to insufficient scope validation.
CVE-2026-20334 New	8.4	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...
CVE-2026-20323 New	8.3	HIGH				A vulnerability in the sftunnel inter-device communication protocol of Cisco Secure FMC Software and Cisco Secure FTD Software could allow an unauthenticated, adjacent attacker to impersonate the peer device and obtain access at the level of the manager role, which is equivalent to root. This vulnerability is due to improper management of the TLS certificate for the sftunnel management connection. An attac...
CVE-2026-88033 Newly scored	8.3	HIGH		0.003	mongodb:java_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Java Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-76413 New	8.2	HIGH				A vulnerability in Cisco Adaptive Security Device Manager (ASDM) single sign-on (SSO) handler for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to log in as the Cisco ASDM administrator user. This vulnerability is due to improper management of the Cisco ASDM SSO token. An attacker could exploit this vulnerability by performing session token forgery techniques. A successful exploit co...
CVE-2026-78252 New	8.2	HIGH		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 15.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an authenticated user could have induced a targeted user to perform unintended state-changing HTTP requests due to improper sanitization of user-controlled data in the Markdown JSON table renderer.
CVE-2026-20335 New	8.1	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Adaptive Security Appliance Software, Cisco Secure Firewall Threat Defense Software and Cisco Secure Firewall Management Center Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabil...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69813 Newly scored	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69858 Newly scored	8.1	HIGH		0.007	microsoft:windows_server_2022, microsoft:windows_server_2025	Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69989 Newly scored	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in DNS Server allows an unauthorized attacker to execute code over a network.
CVE-2026-70342 Newly scored	8.1	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Ancillary Function Driver for WinSock allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-70563 Newly scored	8.1	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper link resolution before file access ('link following') in Windows Shell allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-74909 New	8.1	HIGH				Keycloak provides a policy enforcer to protect applications by matching incoming web requests against defined security policies. A flaw was found where the enforcer fails to correctly normalize web addresses that contain special encoded characters, such as those representing semicolons or directory traversal segments. An authenticated user can use these encoded characters to trick the enforcer into applying a less...
CVE-2026-78450 Newly scored	8.1	HIGH		0.005	microsoft:windows_10_1809, microsoft:windows_server_2019, microsoft:windows_server_2022, microsoft:windows_server_2025	Use after free in Reliable Multicast Transport Driver (RMCAT) allows an unauthorized attacker to execute code over a network.
CVE-2026-82066 Newly scored	8.1	HIGH		0.002	mongodb:mongodb	A heap out-of-bounds read security issue exists in the query planning component of MongoDB Server. An authenticated user with database read and write privileges can trigger the security issue through crafted query operations, causing the server to read memory beyond allocated buffer boundaries. The revealed memory contents may be partially observable through diagnostic query statistics output.
CVE-2026-69423 Newly scored	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Video Driver allows an authorized attacker to elevate privileges over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69503 Newly scored	8.0	HIGH		0.008	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Stack-based buffer overflow in Windows USB Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-85469 New	8.0	HIGH				A flaw was found in quay-builder-qemu. A remote attacker could exploit this by compromising the upstream `Noelware/docker-manifest-action` used in the release workflow, which is pinned to a mutable branch. This allows the attacker to inject arbitrary code, leading to the exfiltration of sensitive registry credentials or the publication of malicious images. The workflow also exposes the default GitHub token, increa...
CVE-2026-92127 New	8.0	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier automatically approves the classpath entries in an item configuration when a user with Overall/Administer permission copies the item, or updates that configuration through the REST API or CLI, allowing attackers able to define classpath entries to execute arbitrary code in the context of the Jenkins controller JVM.
CVE-2026-92134 New	8.0	HIGH				Jenkins Warnings Plugin 13.10258.va_17d49a_78c3b_ and earlier does not validate the analysis results ID when a job configuration is submitted through the REST API, allowing attackers with Item/Configure permission to use a javascript: scheme URL as identifier, resulting in a stored cross-site scripting (XSS) vulnerability.
CVE-2026-92135 New	8.0	HIGH				Jenkins Coverage Plugin 3.3358.v9487dde48783 and earlier does not validate the coverage results ID when a job configuration is submitted through the REST API, allowing attackers with Item/Configure permission to use a javascript: scheme URL as identifier, resulting in a stored cross-site scripting (XSS) vulnerability.
CVE-2026-92136 New	8.0	HIGH				Jenkins OWASP Dependency-Check Plugin 5.6.4 and earlier does not escape CWE values from Dependency-Check reports on the Jenkins UI, resulting in a stored cross-site scripting (XSS) vulnerability exploitable by attackers with Item/Configure permission.
CVE-2026-69270 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69295 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69307 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69571 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69584 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69687 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69707 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69822 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Numeric truncation error in Windows Kerberos allows an authorized attacker to elevate privileges locally.
CVE-2026-69841 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Encrypting File System (EFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69844 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69900 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Untrusted pointer dereference in Kernel Streaming WOW Thunk Service Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69907 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper handling of insufficient permissions or privileges in Windows Enterprise App Management allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69921 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-70564 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-70569 Newly scored	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-71334 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NFS Portmapper allows an authorized attacker to elevate privileges locally.
CVE-2026-77500 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Release of invalid pointer or reference in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-20342 New	7.7	HIGH				A vulnerability in a specific file download API of Cisco Secure FMC Software could allow an authenticated, remote attacker to download arbitrary files from an affected system. This vulnerability exists because user input is not being sanitized. An attacker could exploit this vulnerability by sending a crafted HTTPS request. A successful exploit could allow the attacker to download arbitrary files from the affec...
CVE-2026-73496 Newly scored	7.7	HIGH		0.003		MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the confluence_upload_attachment and confluence_upload_attachments tools pass a client-controlled file_path through src/mcp_atlassian/confluence/attachments.py upload_attachment, and the jira_update_issue_attachments parameter reaches src/mcp_atlassian/jira/attachments.py upload_attachment, without...
CVE-2026-76425 New	7.6	HIGH				A vulnerability in the APIs of Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks against the backend database. This vulnerability is due to insufficient validation of certain parameters that are concatenated directly into an SQL query. An attacker could exploit this vulnerability by sending a crafted request that contains SQL statements to an affected endpoint. A successfu...
CVE-2026-82053 Newly scored	7.6	HIGH		0.002	mongodb:mongodb	A security issue exists in MongoDB's LDAP authorization integration where pooled LDAP connections can retain stale authentication identities after user authentication under certain configurations. Subsequent authorization queries may execute under an unintended LDAP identity rather than the expected one. This can result in incorrect role assignments based on the LDAP directory's access control configuration, poten...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-14871 New	7.5	HIGH		0.006		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.4.6 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an unauthenticated user to cause denial of service due to improper resource allocation limits in the GraphQL complexity calculation logic.
CVE-2026-1168 New	7.5	HIGH		0.006		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.4.6 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an unauthenticated user to cause denial of service due to improper resource allocation limits in the GraphQL complexity calculation logic.
CVE-2026-18212 New	7.5	HIGH				A flaw was found in the SAML Redirect Binding implementation of Keycloak, an open-source identity and access management solution. The issue occurs because the custom DEFLATE compression and decompression helpers fail to release native zlib memory after use. An unauthenticated attacker can exploit this by sending repeated malformed SAML requests, leading to native memory exhaustion and a denial of service.
CVE-2026-20247 New	7.5	HIGH				A vulnerability in Cisco ISE could allow an unauthenticated, remote attacker to conduct SQL injection attacks on an affected device. This vulnerability is due to improper validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafted request to an affected device. A successful exploit could allow the attacker to modify data in the underlying database.
CVE-2026-20343 New	7.5	HIGH				A vulnerability in a critical API for Cisco Secure FMC Software could allow an unauthenticated, remote attacker to download sensitive files and use unbounded disk space. This vulnerability exists because a critical API lacks authentication. An attacker could exploit this vulnerability by repeatedly invoking the API. A successful exploit could allow the attacker to download sensitive files that should be re...
CVE-2026-67376 Newly scored	7.5	HIGH		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Integer overflow or wraparound in SQL Server allows an unauthorized attacker to deny service over a network.
CVE-2026-69852 Newly scored	7.5	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-69881 Newly scored	7.5	HIGH		0.012	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Null pointer dereference in Windows IKE Extension allows an unauthorized attacker to deny service over a network.
CVE-2026-69890 Newly scored	7.5	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Virtual Trusted Platform Module allows an authorized attacker to elevate privileges locally.
CVE-2026-71330 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to disclose information over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-72928 Newly scored	7.5	HIGH		0.006	microsoft:windows_server_2025	Use after free in Windows DNS allows an authorized attacker to execute code over a network.
CVE-2026-76442 Newly scored	7.5	HIGH		0.004		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76442 are related to issues with impr...
CVE-2026-77494 Newly scored	7.5	HIGH		0.012	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77498 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77499 Newly scored	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77501 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77502 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77886 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77888 Newly scored	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77889 Newly scored	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77890 Newly scored	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77893 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77895 Newly scored	7.5	HIGH		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-79651 New	7.5	HIGH				A flaw was found in the theme localization endpoints of the keycloak-services component, which is the core service responsible for authentication flows and theme management in Keycloak. The issue occurs because the system accepts arbitrary locale tags from unauthenticated requests and stores them in a permanent in-memory cache without limits. An attacker can exploit this by sending a large number of unique locale ...
CVE-2026-88032 Newly scored	7.5	HIGH		0.002	mongodb:java_driver	A use-after-free in the reactive client-side encryption component of the MongoDB Java Driver can cause native resources to be freed while an affected encrypted operation is still using them when the operation is cancelled. A party able to cause such an operation to be cancelled may cause the hosting application process to terminate. Reaching the issue requires an affected reactive encryption configuration that ret...
CVE-2026-92128 New	7.5	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier downloads a JAR file specified by URL twice, confirming the approval of the first download and loading the classpath entries from the second, allowing attackers able to define classpath entries to execute arbitrary code in the context of the Jenkins controller JVM.
CVE-2026-92129 New	7.5	HIGH				Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not check calls from sandboxed scripts to methods added dynamically to a class at runtime, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to bypass the sandbox protection and execute code outside the sandbox.
CVE-2026-9336 Newly scored	7.5	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted HTTP request to an administrative endpoint. A remote attacker could exploit this vulnerability to cause the server to exhaust filesystem space.
CVE-2026-20222 New	7.4	HIGH				A vulnerability in the EIGRP implementation in Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, adjacent attacker to cause the device to reload unexpectedly, resulting in a denial of service (DoS) condition. This vulnerability is due to improper resource management when handling EIGRP update messages. An atta...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-17526 New	7.2	HIGH				Keycloak is an open-source identity and access management solution. A vulnerability was discovered where a user with the impersonation role can impersonate a realm administrator. This allows the attacker to gain full administrative control over the realm, including the ability to manage users, clients, and roles.
CVE-2026-76424 New	7.2	HIGH				A vulnerability in the REST API of Cisco ISE could allow an authenticated, remote attacker to upload or copy arbitrary files on an affected device. This vulnerability is due to insufficient validation in file operations. An attacker could exploit this vulnerability by uploading a file with a crafted path. A successful exploit could allow the attacker to upload files to arbitrary locations and execute arbitrary ...
CVE-2026-82061 Newly scored	7.2	HIGH		0.003	mongodb:mongodb	A use-after-free security issue exists in the server's query execution memory tracking subsystem. An authenticated user with read privileges can trigger a write to freed heap memory through a sequence of standard database commands, leading to server process crash or potential memory corruption. No user interaction is required.
CVE-2026-82071 Newly scored	7.2	HIGH		0.003	mongodb:mongodb	Insufficient validation of storage engine configuration options in MongoDB Server allows an authenticated user with write privileges to supply crafted parameters during collection creation that override internal storage metadata. This results in an out-of-bounds memory write in the server process, causing a denial of service via server crash, with potential for further impact including arbitrary code execution.
CVE-2026-20300 New	7.1	HIGH				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to conduct SQL injection attacks on an affected device. To exploit this vulnerability, the attacker must have at least low-privileged administrative credentials. This vulnerability is due to improper validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafted request to an affected device. A succe...
CVE-2026-82052 Newly scored	7.1	HIGH		0.004	mongodb:mongodb	The \$regexFindAll expression can be used by an authenticated user who can run aggregation pipeline stages to crash a MongoDB server (mongod). Under certain specific conditions the regex match can start in the middle of a multi-code-unit character, triggering an assertion during query execution.
CVE-2026-82054 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A security issue exists in MongoDB server's JSON Pointer parser used during \$jsonSchema query filter processing. When a find command includes a specially crafted \$jsonSchema filter field, the parser processes the input without enforcing adequate limits on iteration count or total allocation size, resulting in significant memory amplification. Under concurrent request load, the cumulative memory consumption can exh...
CVE-2026-82055 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A security issue exists in MongoDB's 2dsphere index key generation that can cause a server crash due to a null pointer dereference. When a specially crafted GeoJSON document is inserted into a collection with a 2dsphere index, an inconsistency in geometry parsing can leave an internal object in an invalid, partially initialized state. During subsequent index key generation, access to this improperly initialized ob...
CVE-2026-82057 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A security issue was discovered in MongoDB where an authenticated user with readWrite privileges could crash the mongod server process. By specifying a custom WiredTiger storage configuration option with an incompatible value during collection creation, a user could cause a type confusion in the storage engine layer. When documents were subsequently read from the misconfigured collection, the resulting mismatch in...
CVE-2026-82058 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A flaw in MongoDB's JSON Schema validation error generation code allows an authenticated user with readWrite privileges to crash the mongod server. When a BSON document containing an array with a malformed numeric field name fails a \$jsonSchema items type constraint, the error generation path performs unsafe numeric conversion on the user-controlled field name without proper exception handling, resulting in an unc...
CVE-2026-82065 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A security issue in the MongoDB Server's storage engine integration layer allows an authenticated user with collection creation privileges to cause a persistent denial of service. Insufficient validation of user-supplied storage configuration options permits values that, once persisted to durable metadata, trigger a fatal assertion failure when the metadata is subsequently read by diagnostic operations. The corrup...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82068 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A security issue in MongoDB Server allows an authenticated user with write privileges to trigger a persistent fatal assertion crash by sending specially crafted retryable write commands. The crash state is durably persisted, causing the server process to repeatedly crash on restart and potentially propagating to additional nodes in a sharded cluster. Manual intervention is required to restore service availability.
CVE-2026-82070 Newly scored	7.1	HIGH		0.002	mongodb:mongodb	A security issue in MongoDB Server's diagnostic reporting interface allows an authenticated user with monitoring privileges to access insufficiently protected credentials from concurrent administrative operations. The same credentials are properly redacted in server log output, but the diagnostic interface omits equivalent redaction. Successful exploitation requires a valid authenticated session with monitoring-le...
CVE-2026-82073 Newly scored	7.1	HIGH		0.003	mongodb:mongodb	A security issue in the MongoDB Server aggregation framework allows an authenticated user with limited read privileges to bypass view-level authorization checks and access data from unauthorized collections when Atlas Search features are in use. The issue stems from insufficient validation of an internal command parameter that can be set by external clients, causing a security check to be improperly skipped.
CVE-2026-82074 Newly scored	7.1	HIGH		0.002	mongodb:mongodb	MongoDB Server contains an incorrect authorization vulnerability in the aggregation framework. An authenticated user with minimal privileges can craft a specially formatted aggregation request that causes the server's authorization subsystem to evaluate a different operation than what is actually executed, resulting in unauthorized read access to collection data within the target database.
CVE-2026-92456 New	7.1	HIGH				yshop-crm through 2.1.3 fails to enforce authorization on the saveRedisSet and getRedisSet endpoints in CrmCustomerController, allowing any authenticated back-office user to read and modify installation-wide lead-allocation and customer auto-recycling policy. Attackers can invoke these endpoints to manipulate shared Redis keys controlling customer auto-recycling behavior, causing mass customer data deletion, disab...
CVE-2026-68840 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69319 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69413 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69422 Newly scored	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Use after free in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69814 Newly scored	7.0	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Credential Providers allows an authorized attacker to elevate privileges locally.
CVE-2026-69816 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Accounts Control allows an authorized attacker to elevate privileges locally.
CVE-2026-69817 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Bluetooth Port Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69818 Newly scored	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69834 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-69838 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-69859 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Time-of-check time-of-use (toctou) race condition in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69866 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69889 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69891 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Media allows an authorized attacker to elevate privileges locally.
CVE-2026-69896 Newly scored	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Use after free in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69911 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-70283 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Incorrect authorization in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-70562 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Double free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70565 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows AF_UNIX Socket Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-70567 Newly scored	7.0	HIGH		0.003	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Double free in Windows Display Enhancement Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70568 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Defender Firewall Service allows an authorized attacker to elevate privileges locally.
CVE-2026-71332 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71333 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-73022 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-77894 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-77899 Newly scored	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2012	Use after free in Windows Security Center allows an authorized attacker to elevate privileges locally.
CVE-2026-82062 Newly scored	7.0	HIGH		0.004	mongodb:mongodb	A security issue in MongoDB Server allows an authenticated user with elevated internal privileges to bypass a disabled feature gate in the applyOps command by specifying an internal replication mode value that was not intended to be client-selectable. This bypass enables execution of container operations that are disabled by default in production configurations, allowing direct storage-engine writes to arbitrary i...
CVE-2026-20248 New	6.8	MEDI				A vulnerability in the DNS over TCP implementation of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause the TCP DNS response handler to unexpectedly restart, causing the device to reload. This vulnerability is due to a logic error when parsing a DNS query and tracking the size of ...
CVE-2026-69490 Newly scored	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Mass Storage Class Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-77892 Newly scored	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	No cwe for this issue in Windows Boot Manager allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-92140 New	6.8	MEDI				Jenkins Gitee Plugin 1301.v8957053c7902 and earlier does not escape the sender name from Gitee push webhook payloads in build causes, resulting in a stored cross-site scripting (XSS) vulnerability exploitable by attackers able to trigger builds via the Jenkins Gitee Plugin webhook endpoint.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69469 Newly scored	6.6	MEDI		0.004	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Integer overflow or wraparound in Windows USB Audio Class driver (usbaudio.sys) allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-20283 New	6.5	MEDI				A vulnerability in the IPsec Open API endpoint of Cisco ISE could allow an authenticated, remote attacker to inject arbitrary commands on the underlying operating system. This vulnerability is due to insufficient validation of user-supplied input in IPsec Open API calls. An attacker could exploit this vulnerability by sending crafted input to the IPsec Open API endpoint on an affected device. A successful...
CVE-2026-20287 New	6.5	MEDI				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) engineering teams have conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20287 are ...
CVE-2026-53716 Newly scored	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, getFileFromGZ in internal/wasm/httpfetcher.go calls io.ReadAll on a gzip.Reader without limiting decompressed output when a tenant-controlled EnvoyExtensionPolicy.spec.wasm[].code.http.url points to a reachable compressed Wasm payload. The 256 MiB compressed-input cap ...
CVE-2026-53719 Newly scored	6.5	MEDI		0.007		Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, translateSecurityPolicyForRoute in internal/gatewayapi/securitypolicy.go dereferences a nil authorization value when a namespace-scoped tenant creates a SecurityPolicy targeting a TCPRoute and omits spec.authorization. The persistent object triggers the panic on every ...
CVE-2026-62801 Newly scored	6.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper limitation of a pathname to a restricted directory ('path traversal') in Windows PowerShell allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-66816 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2022, microsoft:sql_server_2025	Insufficient logging in SQL Server allows an authorized attacker to bypass a security feature over a network.
CVE-2026-67369 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67383 Newly scored	6.5	MEDI		0.01	microsoft:sql_server_2025	Generation of error message containing sensitive information in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67386 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use of uninitialized resource in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67633 Newly scored	6.5	MEDI		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to deny service over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69839 Newly scored	6.5	MEDI		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Uncaught exception in Windows iSCSI Target Service allows an authorized attacker to deny service over a network.
CVE-2026-70019 Newly scored	6.5	MEDI		0.011	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Windows hard link in Windows Compressed Folder allows an unauthorized attacker to disclose information over a network.
CVE-2026-76438 New	6.5	MEDI				A vulnerability in the web-based management interface of Cisco BroadWorks CommPilot Application Software could allow an authenticated, remote attacker with low privileges to alter configurations on an affected device. This vulnerability is due to missing authorization checks. An attacker could exploit this vulnerability by sending a crafted HTTP request. A successful exploit could allow the attacker to alt...
CVE-2026-82059 Newly scored	6.5	MEDI		0.003	mongodb:mongodb	An internal aggregation expression in MongoDB Server was incorrectly registered as accessible to any authenticated user rather than being restricted to internal cluster operations. By crafting a malformed index specification within this expression, an authenticated user with read-only privileges could trigger an assertion failure in the index key generation code path. In certain build configurations, this assertio...
CVE-2026-82069 Newly scored	6.5	MEDI		0.003	mongodb:mongodb	A security issue in MongoDB Server's query statistics serialization on the router allows users with monitoring privileges to access unredacted search query text from other users' operations. An improper conditional check in the serialization logic causes the data redaction mechanism to be bypassed when processing search queries through the sharded cluster router. This results in sensitive query literals being stor...
CVE-2026-84859 New	6.5	MEDI				ScadaLTS 2.8.1-release-candidate build 0 is affected by an Authenticated Blind SQL Injection The /api/events/search endpoint accepts a JSON body containing a sortBy array. The values in this array are concatenated directly into the SQL ORDER BY clause without any sanitization or parameterization. This allows authenticated users with the ROLE_USER role to perform time-based and boolean-based blind SQL injection ...
CVE-2026-84993 New	6.5	MEDI				MikroORM is a TypeScript ORM for Node.js based on Data Mapper, Unit of Work and Identity Map patterns. Prior to 6.6.16 and 7.1.7, the shared SQL layer validates the field key of an orderBy clause but does not validate its direction value before AbstractSqlPlatform.getOrderByExpression concatenates it into an ORDER BY clause. Applications that bind attacker-controlled request data to the direction in em.find(), em....
CVE-2026-92139 New	6.5	MEDI				Jenkins Bitbucket Push and Pull Request Plugin 4.0.1 and earlier trusts values provided in the webhook payload, including certain URLs, and uses configured Bitbucket credentials to connect to those URLs, allowing attackers to capture Bitbucket credentials stored in Jenkins by sending a crafted webhook payload.
CVE-2026-92468 New	6.5	MEDI				zlt2000 microservices-platform through 6.0.0 contains an authorization bypass vulnerability in the search-center service that allows authenticated attackers to read any Elasticsearch index by specifying the index name in POST /search/{indexName} and GET /agg/requestStat/{indexName}/{routing} path variables. Attackers can query arbitrary indices including sys_user to retrieve sensitive user records and password has...
CVE-2026-92750 New	6.5	MEDI				Harness through 3.3.0 omits access control validation in the infrastructure provider read endpoint, allowing authenticated users to retrieve provider configurations from spaces they do not belong to. Attackers can query the GET /api/v1/infraproviders endpoint with arbitrary space identifiers to expose sensitive provider metadata including Docker endpoints, TLS certificate paths, and cloud project identifiers.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2024-11222 New	6.4	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed a developer user to perform actions in the context of another user's merge request commit due to a race condition issue in pipeline creation.
CVE-2026-69874 Newly scored	6.4	MEDI		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Untrusted pointer dereference in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-77887 Newly scored	6.4	MEDI		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-77891 Newly scored	6.4	MEDI		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-92358 New	6.4	MEDI		0.003		A flaw was found in the first broker login flow of Keycloak. When a user confirms an account-linking request from a different browser, a temporary proof is created to validate the link. However, this proof is not properly cleared after the link is established or when the user later manually removes the link. An attacker who controls the external identity can exploit this leftover proof to silently re-establish the...
CVE-2026-20309 New	6.1	MEDI				A vulnerability in the web-based management interface of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to conduct a reflected cross-site scripting (XSS) attack against a user of the interface. This vulnerability exists because the web-based management interface does not properly validate user-supplied input. An attacker could exploit this vulnerability by persuading a user...
CVE-2026-88034 Newly scored	6.1	MEDI		0.003	mongodb:c\+\+_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C++ Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ...
CVE-2026-88036 Newly scored	6.1	MEDI		0.003	mongodb:c_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ch...
CVE-2026-82056 Newly scored	6.0	MEDI		0.002	mongodb:mongodb	A race condition in MongoDB server's text index query parsing can cause a heap use-after-free read when handling upsert retry paths. Under certain concurrent index lifecycle operations, a raw pointer to internal text index metadata may be dereferenced after the underlying structures have been freed, leading to a server crash. An authenticated user with readWrite privileges can trigger this condition through specif...
CVE-2026-82063 Newly scored	6.0	MEDI		0.003	mongodb:mongodb	A use-after-free security issue in the cursor management component of MongoDB Server allows an authenticated user to cause a denial of service. Under specific timing conditions during cursor operations, a stale pointer to a freed resource may be retained and subsequently dereferenced during cursor cleanup, leading to a server process crash.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-70091 Newly scored	5.9	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-92591 New	5.9	MEDI				Craft CMS 5.0.0 through 5.10.12 treats a database connection failure as meaning that Craft is not installed, which makes anonymous installer actions — including install/validate-site — reachable on an installed production site whenever PHP remains available but the configured MySQL endpoint does not. The action accepts a site name, serializes it through Site::getName(), and expands \${NAME} expressions using App::e...
CVE-2026-20120 New	5.8	MEDI				A vulnerability in the access control list (ACL) Object Group Search (OGS) implementation of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to bypass configured access controls. This vulnerability is due to a logic error in populating group access control policies (ACPs) with OGS configured....
CVE-2026-20290 New	5.8	MEDI				A vulnerability in SSL/TLS certificate parsing in the Snort 2 Detection Engine of Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause the Snort 2 Detection Engine to restart. This vulnerability is due to incomplete validation of the SSL certificate. An attacker could exploit this vulnerability by sending a crafted SSL connection setup request to be parsed...
CVE-2026-54246 Newly scored	5.7	MEDI		0.003		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.27.13, the routesrv component serves cluster-wide control-plane data without application-layer authentication through /routes, /routes/{zone}, /swarm/redis/shards, and /swarm/valkey/shards. The handlers registered in routesrv/routesrv.go, eskipBytes.ServeHTTP in routesrv/eskipbytes.go, RedisHandler.ServeHTTP in routesrv/redishandler.go...
CVE-2026-68830 Newly scored	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper link resolution before file access ('link following') in Windows Universal Plug and Play (UPnP) Device Host allows an authorized attacker to disclose information locally.
CVE-2026-68831 Newly scored	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Files or directories accessible to external parties in Windows Defender Firewall Service allows an authorized attacker to disclose information locally.
CVE-2026-69286 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to disclose information locally.
CVE-2026-69343 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Overlay Filter allows an authorized attacker to disclose information locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69457 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Driver allows an authorized attacker to disclose information locally.
CVE-2026-69527 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows USB Mass Storage Class Driver allows an authorized attacker to disclose information locally.
CVE-2026-69808 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69862 Newly scored	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Wireless Wide Area Network Service allows an authorized attacker to disclose information locally.
CVE-2026-70145 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Microsoft Windows Search Component allows an authorized attacker to disclose information locally.
CVE-2026-77491 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows GDI allows an unauthorized attacker to disclose information locally.
CVE-2026-88035 Newly scored	5.5	MEDI		0.001	mongodb:c_driver	A size check in the client-side authentication path of the MongoDB C Driver can wrap around, so an unusually large user-name value is accepted and copied past the end of a small buffer. A party able to set the driver's connection settings may cause the application that embeds the driver to terminate unexpectedly. Reaching this code requires a build in which the optional external SASL authentication backend is pres...
CVE-2026-92132 New	5.4	MEDI				Jenkins Gradle Plugin 2.19.1252.v15196b_5a_6e10 and earlier requests build scan data from the build scan link detected in the build log, even when a Develocity server URL is configured in the global configuration, allowing attackers able to control the build log to capture the Develocity access key configured in the global configuration by having Jenkins connect to an attacker-specified URL.
CVE-2026-92133 New	5.4	MEDI				Jenkins GitLab Plugin 1.2149.vcfc32c82b_f7f and earlier caches the GitLab API client built for alternative GitLab API token credentials under a cache key derived from the credentials ID alone, omitting the folder in which the credentials are resolved, allowing attackers with Item/Configure permission to access GitLab API token credentials they are not entitled to use.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19607 New	5.3	MEDI				A flaw was found in the first-broker-login flow of the keycloak-services component. This component handles the initial authentication and account linking when a user logs in via an external identity provider. The issue allows an attacker to register a matching username on an external provider to trigger a collision in Keycloak, which results in the legitimate user being locked out of their account.
CVE-2026-20121 New	5.3	MEDI				A vulnerability in the access control list (ACL) Object Group Search (OGS) implementation of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to bypass configured access controls. This vulnerability is due to a logic error in populating group access control policies (ACPs) with OGS configured....
CVE-2026-76433 New	5.3	MEDI				A vulnerability in the client provisioning download feature of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to access protected files on an affected device. This vulnerability is due to insufficient validation of directory traversal character sequences in a user-supplied path when the software processes provisioning resource requests. An attacker could exploit this vulnerability b...
CVE-2026-76439 New	5.3	MEDI				A vulnerability in the endpoint posture status reporting functionality of the guest portal web application of Cisco ISE could allow an unauthenticated, remote attacker to submit forged posture status events into the endpoint posture pipeline. This vulnerability is due to insufficient authentication on an internal interface that is exposed through the guest portal. An attacker could exploit this vulnerability by...
CVE-2026-76444 New	5.3	MEDI				A vulnerability in an internal service of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to retrieve sensitive configuration information from an affected device. This vulnerability is due to missing authentication on the Policy Runtime Repository Table (PRRT) service. An attacker could exploit this vulnerability by sending a crafted request to an affected device. A successful exploi...
CVE-2026-76447 New	5.3	MEDI				A vulnerability in the Online Certificate Status Protocol (OCSP) responder of Cisco ISE and Cisco ISE-PIC could allow an unauthenticated, remote attacker to cause an administrative reload of the OCSP responder certificate and key material. This vulnerability is due to missing authentication on a function of the OCSP responder. An attacker could exploit this vulnerability by sending a crafted request to an affec...
CVE-2026-92568 New	5.3	MEDI				MLRun through 1.11.0 contains a server-side request forgery vulnerability in the WebhookNotification handler that allows authenticated users to make the API server send arbitrary HTTP requests to internal addresses. Attackers can update a run with a malicious webhook notification that executes when the run reaches a terminal state, enabling requests to internal services, Kubernetes APIs, or cloud metadata endpoint...
CVE-2026-9338 Newly scored	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted request. A remote attacker could exploit this vulnerability to trigger excessive resource consumption, potentially leading to reduced availability of the affected service.
CVE-2026-90563 Newly scored	5.1	MEDI		0.002		A vulnerability was determined in maliangnansheng bbs-springboot 3.0.0. This affects the function utils.toToc of the file ArticleController.java. This manipulation causes cross site scripting. The attack is possible to be carried out remotely.
CVE-2026-19729 Newly scored	4.9	MEDI		0.005		A flaw was found in the key provider component of the keycloak-services library, which is the core engine for the Red Hat Build of Keycloak. The issue occurs because a previous fix for path probing was incomplete, allowing a realm administrator to still submit arbitrary filesystem paths as keystore parameters. This can be used to determine the existence and readability of files on the server, potentially exposing ...
CVE-2026-20072 New	4.9	MEDI				A vulnerability in the web-based management interface of Cisco ISE could allow an authenticated, remote attacker to obtain sensitive information from network users that are outside the security group that the attacker is assigned to. This vulnerability exists because certain files lack proper authorization enforcement. An attacker with administrative privileges and management rights over network users co...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20235 New	4.9	MEDI				A vulnerability in the API of Cisco Identity Services Engine (ISE) could allow an authenticated, remote attacker to view sensitive information on an affected device. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to insufficient validation of user-supplied parameters in API requests. An attacker could exploit this vulnerability by sending a craf...
CVE-2026-20282 New	4.9	MEDI				A vulnerability in Cisco ISE could allow an authenticated, remote attacker to obtain write access on the underlying operating system of an affected device. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this vulnerability by sending a crafted HTTP request to an affected device. A successful exploit could allow the attacker to obtain write access to the und...
CVE-2026-76426 New	4.9	MEDI				A vulnerability in the REST API of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to conduct SQL injection attacks against the monitoring database. This vulnerability is due to insufficient validation of specific parameters that are then concatenated into an SQL statement. An attacker could exploit this vulnerability by sending a crafted request that contains SQL statements in one of ...
CVE-2026-76427 New	4.9	MEDI				A vulnerability in the offline profiler feed service of Cisco ISE could allow an authenticated, remote attacker to read arbitrary files that are stored on an affected device. This vulnerability is due to the parsing of attacker-controlled feed metadata with an XML parser that does not disable external entity resolution. An attacker could exploit this vulnerability by uploading a crafted offline feed package thr...
CVE-2026-76428 New	4.9	MEDI				A vulnerability in the REST APIs of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to conduct SQL injection attacks against the session database. This vulnerability is due to certain parameters being concatenated directly into SQL clauses without parameterization. An attacker could exploit this vulnerability by sending a crafted request that contains SQL statements in one of the affec...
CVE-2026-76431 New	4.9	MEDI				A vulnerability in the file management function of the web-based management interface of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to delete arbitrary files and directories on an affected device. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to improper validation of directory traversal character sequences in a u...
CVE-2026-76432 New	4.9	MEDI				A vulnerability in the web-based management interface of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker with administrative-level privileges to write arbitrary files on an affected device. This vulnerability exists because the affected software does not properly validate directory traversal character sequences in a user-supplied file path during the upload process. An attacker could e...
CVE-2026-76434 New	4.9	MEDI				A vulnerability in the certificate import functionality of the web-based management interface of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to read arbitrary files from the affected system. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to insufficient validation of user-supplied input by the affected feature. An a...
CVE-2026-76446 New	4.9	MEDI				A vulnerability in an API of Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to read specific files on the underlying operating system of an affected device. This vulnerability is due to improper restriction of XML external entity references. An attacker could exploit this vulnerability by sending a crafted request to an affected device. A successful exploit could allow the attack...
CVE-2026-76448 New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker could exploit this vulnerability by sendin...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76449 New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker could exploit this vulnerability by sendin...
CVE-2026-76450 New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker could exploit this vulnerability by sendin...
CVE-2026-76451 New	4.9	MEDI				A vulnerability in Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to conduct an SQL or HQL injection attack on an affected device. This vulnerability is due to insufficient validation of user-supplied input to the affected APIs before it is used to build database queries. An attacker could exploit this vulnerability by sendin...
CVE-2026-89298 Newly scored	4.9	MEDI		0.002		A flaw was found in the Dynamic Client Registration service of Keycloak, an open-source identity and access management solution. The issue occurs when a user with the view-clients role accesses the client registration endpoint to retrieve client details. Due to a failure to mask sensitive information, the service returns the client's confidential secret in cleartext. This could allow a read-only administrator to o...
CVE-2026-19619 New	4.7	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an unauthenticated user to execute arbitrary JavaScript in the context of a targeted user's session due to improper sanitization of pasted HTML content in the Content Editor.
CVE-2026-20350 New	4.7	MEDI				A vulnerability in the web-based management interface of Cisco ThousandEyes Virtual Appliance could allow an authenticated, remote attacker to inject arbitrary operating system commands. This vulnerability is due to improper validation of user-supplied input to the web-based management interface. An attacker could exploit this vulnerability by saving configuration details that contain malicious values. A succes...
CVE-2026-68849 Newly scored	4.7	MEDI		0.002	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Out-of-bounds read in Windows Bluetooth Port Driver allows an authorized attacker to disclose information locally.
CVE-2026-69832 Newly scored	4.7	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69853 Newly scored	4.7	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use of uninitialized resource in Windows Win32K allows an authorized attacker to disclose information locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69895 Newly scored	4.7	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-69548 Newly scored	4.6	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78547 Newly scored	4.4	MEDI		0.002		Out-of-bounds write vulnerability in Citrix Citrix Workspace app for Windows. This issue affects Citrix Workspace app for Windows: before 2603.11 Current Release (CR), before 2507.1 LTSR CU3, and before LTSR 2607.
CVE-2026-86341 New	4.4	MEDI		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 17.1 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an authenticated user with Owner or Maintainer permissions could have silently disabled protected environment deployment approval requirements, allowing unapproved deployments to reach production, due to improper access control checks performed after...
CVE-2026-16794 New	4.3	MEDI		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 18.11 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user with the Security Manager role to execute arbitrary CI/CD jobs and access protected variables within group projects due to improper authorization controls on compliance framework management.
CVE-2026-20285 New	4.3	MEDI				A vulnerability in the web-based management interface of Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) could allow an authenticated, remote attacker to modify parts of the configuration on an affected device. This vulnerability is due to the lack of server-side validation of Administrator permissions. An attacker could exploit this vulnerability by submitting ...
CVE-2026-20286 New	4.3	MEDI				A vulnerability in the web-based management interface of Cisco Identify Services Engine (ISE) could allow an authenticated, remote attacker to modify parts of the configuration on an affected device. This vulnerability is due to the lack of server-side validation of Administrator permissions. An attacker could exploit this vulnerability by submitting a crafted HTTP request to an affected system. A suc...
CVE-2026-54247 Newly scored	4.3	MEDI		0.002		Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.26.22, Handler in dataclients/kubernetes/admission/admission.go passes the body of requests to the Kubernetes admission endpoint at :9443/admission directly to io.ReadAll(r.Body) without a size limit. An attacker with in-cluster network access and a valid Kubernetes client certificate can send a very large body that causes unbounded me...
CVE-2026-73019 Newly scored	4.3	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper resolution of path equivalence in Windows URL Moniker allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-7514 New	4.3	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.9 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that an authenticated user with developer-role permissions could substitute package file content and hide packages from their owners due to improper authorization checks in the Generic Package Registry.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-8030 New	4.3	MEDI		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user to prevent another user from modifying their group settings due to improper validation of group URL slugs during namespace transfers.
CVE-2026-92141 New	4.3	MEDI				Jenkins Keycloak Authentication Plugin 2.4.1 and earlier does not restrict the redirect URL after login, allowing attackers to perform phishing attacks.
CVE-2026-92131 New	4.2	MEDI				Jenkins Pipeline: Groovy Libraries Plugin 805.va_fc79344957d and earlier does not restrict the library path provided to the library Pipeline step to a relative path inside the SCM checkout, and follows symbolic links to locations outside of the SCM checkout when retrieving the library, resulting in a path traversal vulnerability, allowing attackers able to configure Pipelines to read files in a resources directory...
CVE-2026-92138 New	4.2	MEDI				The OAuth authorization endpoint in Jenkins Bitbucket Server Integration Plugin 6.0.1 and earlier reads the `oauth_callback` URL from the submitted form rather than from the server-side stored request token, allowing attackers to hijack the OAuth flow and obtain an access token on behalf of the victim.
CVE-2026-20071 New	3.8	LOW				A vulnerability in the SSID bring-your-own-device (BYOD) onboarding workflow of Cisco ISE could allow an unauthenticated, adjacent attacker to hijack the onboarding session of another user and access protected 802.1X networks. This vulnerability is due to insufficient authentication checks that are performed while a user is being onboarded. An attacker could exploit this vulnerability by spoofing th...
CVE-2026-3855 New	3.1	LOW		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.2.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user with project-level permissions to access restricted file contents on the server or cause denial of service due to improper validation of parameters in the Terraform state upload functionality.
CVE-2026-92130 New	3.1	LOW				Jenkins Pipeline: Multibranch Plugin 841.vec5b_9e1806ec and earlier does not set the appropriate context for credentials lookup in the resolveScm Pipeline step, allowing attackers with Item/Configure permission to access and capture credentials they are not entitled to.
CVE-2026-82060 Newly scored	2.3	LOW		0.002	mongodb:mongodb	In MongoDB, insufficient validation of shard key values during document insertion allowed authenticated users to store documents with specially crafted, operator-shaped objects as shard key values in sharded collections. When change stream events for such documents were processed with the updateLookup full document mode, the crafted values were embedded into internal post-image lookup queries without proper saniti...
CVE-2026-90598 Newly scored	2.1	LOW		0.002		A vulnerability was detected in jaygajera17 E-commerce-project-springBoot up to 5e74a46b4b70623d0e4a0c9c4aee3bd1777185d2. The impacted element is the function UserController.updateUser of the file UserController.java. Performing a manipulation of the argument userId results in authorization bypass. It is possible to initiate the attack remotely. The exploit is now public and may be used. This product is using a ro...
CVE-2026-61560 Updated		CRIT		0.007	npm:@zereight/mcp-gitlab fixed: 2.1.27	#### Summary The SSE transport mode (`SSE=true`) exposes all MCP tools without any authentication. The `upload_markdown` tool reads arbitrary files from the server's local filesystem via an unsanitized `file_path` parameter and uploads them to a GitLab project. Combined, any unauthenticated network-reachable attacker can read `/proc/self/environ` to steal the server's `GITLAB_PERSONAL_ACCESS_TOKEN` and achieve ful...
CVE-2026-76186 New				0.002		Apache Airflow Keycloak provider: from Airflow 3.3 the Keycloak auth manager takes a user's identity from the signed Airflow session token but takes the Keycloak access and refresh tokens used for every authorization decision from separate, unauthenticated cookies, and never checks that the two describe the same subject. A user who holds any valid Airflow login of their own, together with another subject's Keycloa...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76187 New				0.002		Apache Airflow Keycloak provider: the unauthenticated token endpoint accepts a client-credentials grant for any confidential client registered in the Keycloak realm, not only the client configured for Airflow. No allowlist restricts which client ids may authenticate, so the credentials of an unrelated application that happens to share the realm are valid Airflow login credentials, and Airflow mints a signed sessio...
CVE-2026-89835 New						In the Linux kernel, the following vulnerability has been resolved: f2fs: avoid NULL checkpoint thread access in sysfs checkpoint_merge can be enabled even when no checkpoint merge thread is running. A read-only mount is one case: f2fs does not start f2fs_issue_ckpt there, but ckpt_thread_ioprio is still writable through sysfs. The ckpt_thread_ioprio store path updates the saved ioprio value and, when checkpoin...
CVE-2026-89953 New						In the Linux kernel, the following vulnerability has been resolved: mtd: mtdoops: free page bitmap when the backing MTD is removed mtdoops_notify_add() allocates oops_page_used when the configured MTD device is registered. mtdoops_notify_remove() detaches from that device but leaves the bitmap allocated. If the same MTD device is later registered again, the add path allocates a new bitmap and overwrites the ol...
CVE-2026-90040 New						In the Linux kernel, the following vulnerability has been resolved: KVM: SEV: Forcefully invalidate SNP VMs if its backing gmem page is zapped Wire up a gmem_invalidate_range() call for SNP VMs, and use it to force vCPUs to reload/recheck their guest-provided VMs if the backing gmem page is being invalidated, e.g. is being PUNCH_HOLE'd. Use the same core logic to handle invalidations as VMX does for the APIC-...
CVE-2026-92126 New						Jenkins Script Security Plugin 1415.v9a_f9b_3a_c253d and earlier does not reject @Builder annotations whose builderStrategy member names an arbitrary class, allowing attackers with permission to define and run sandboxed scripts, including Pipelines, to execute code outside the sandbox if a suitable class is present on the classpath of the component that evaluates the script.

P3/P4 items (1566) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.